Chapter 15 worked solutions • Security

OS15-E01 • Bounds and defense limits

1. Thirteen bytes are needed, one too many. Reject unless $n \leq 11$, or explicitly truncate to 11 data bytes and set buf[11]=0, reporting truncation. Copying 11 without NUL does not establish a valid string.
2. NX checks execution permission, not ordinary write bounds. Adjacent authorization data can be corrupted without executing stack code. Correct copy bounds. Data length, capacity, and terminator differ.

OS15-E02 • Pending-slot denial of service

1. For the same boundary of accepted requests occupying slots, steady-state $L=\lambda W$ gives $\lambda=2000/8=250$ accepted requests/s. Rejected offered requests are excluded, so this does not determine the offered rate. A mean occupancy does not determine first saturation time; bursts and admission limits affect instantaneous occupancy.
2. Users sharing NAT can share one quota, while an attacker can have many sources. Define key/fairness. Rate limiting does not promise harmlessness to authorized users. Units are requests/s, not bytes/s.

OS15-E03 • Reused keystream

1. c1=0xB5, c2=0xD5, c1 XOR c2=0x60=m1 XOR m2. Then s=c1 XOR m1=0xA5 and m2=c2 XOR s=0x70.
2. Associativity and s XOR s=0 prove leakage regardless of generator strength, without brute force. This toy demonstrates reuse, not production encryption.

OS15-E04 • Non-coprime RSA plaintext

1. $c=5^3 \bmod 55=15$. Squares are$15^2 \to 5, 15^4 \to 25, 15^8 \to 20, 15^{16} \to 15$. For$27=16+8+2+1$, multiply$15 \cdot 20 \bmod 55=25$, then $\cdot 5 \to 15$, then $\cdot 15 \to 5$.
2. Modulo5 the plaintext/power are0. Modulo11,5 is coprime and Fermat with $ed=1+2 \cdot 4 \cdot 10$ gives$5^{ed} \equiv 5$. CRT combines both. Euler modulo55 cannot be used under its violated coprimality condition. Correctness is not security of small RSA.

Lin Cing https://github.com/xinhi6716/computer-science-self-study

OS15-E05 • Hashes, MACs, and replay

1. An adversary can replace m with m′ and recompute H(m′). A secure MAC resists forgery but an old pair can be copied. Bind session, message, and unique nonce with unambiguous encoding, and validate freshness state.
2. After tag verification, one lock/transaction checks pending and changes it to used atomically, so only one thread succeeds. This alone does not ensure exactly-once external payment: deduplication and the business effect need atomic or recoverable coordination with a matching external-system contract.

OS15-E06 • Historical TLS identity and secrecy

1. No. A valid signature alone omits name, usage, chain and current peer authentication. Finished verification provides evidence of master-secret derivation and transcript authentication under the protocol and trust assumptions; an intermediary may relay messages. Forwarding a certificate needs no private key.
2. No. The recorded ClientKeyExchange carries an RSA-encrypted premaster. A later stolen static key permits decryption; the public randoms then derive the old master and traffic keys. Deleting traffic keys does not add forward secrecy to this static RSA exchange.

OS15-E07 • Salt and guess cost

1. 500 • 20000=10000000 KDFs, times 0.002=20000 s≈5.556 h. Salt can be public beside the verifier; it separates computations rather than acting as a secret key.
2. No. Offline work bypasses online checks. Stated 2 ms cost still applies. Parallel hardware/memory assumptions are separate; serial modeled time is not measured attack time. Salt prevents easy cross-record table reuse without defeating dictionaries.

OS15-E08 • IDS base rate

1. Attacks100, normal99900; TP90, FN10, FP999, TN98901. Population precision P(attack|alarm)=90/(90+999)=90/1089≈8.264%, the ratio of expected TP to expected alerts. This need not equal the expectation of the finite-sample random ratio TP/(TP+FP); it is not TPR 90%.
2. Require πTPR≥(1−π)FPR, giving FPR≤0.001 • 0.9/0.999≈0.000900901, or0.09009%. Its denominator is normal events. Alarm precision and TPR use different denominators.

OS15-E09 • Firewall permissions

1. Deny, allow, deny, and allow only if the reply matches existing state. Port alone is insufficient; zones, addresses, direction, and state matter. Claiming established does not prove matching state.
2. Yes, through the permitted DB5432 path. Segmentation limits other entries without removing necessary trust. DB credentials, roles, query scope, and monitoring must constrain abuse.

OS15-E10 • Windows 7 DACL and MIC

1. For r, deny intersects no remaining bit, allow removes r, and DACL passes. NWU alone does not block read, so the model allows it. For rw, MIC rejects write-up; independently the DACL deny rejects w. Later allow does not override this rejection.
2. In noncanonical order, allow first empties remaining and DACL succeeds without scanning deny. MIC still rejects write-up. Neither all-denies-always-win nor DACL-success-implies-final-success is correct.
3. NULL has no DACL and permits under the ordinary check. Empty grants nothing, leaving requested bits and denying. Mandatory policy/other checks still apply. Keep each layer separate.

References and attribution

Lin Cing, handwritten operating systems notes. Silberschatz et al., Operating System Concepts, 9th ed., Ch. 15. RFC 5246. RFC 7568. Microsoft: DACL. Microsoft: MIC.

Original educational synthesis by Lin Cing, licensed under CC BY 4.0.
https://github.com/xinhi6716/computer-science-self-study